DHCP SPOOFING

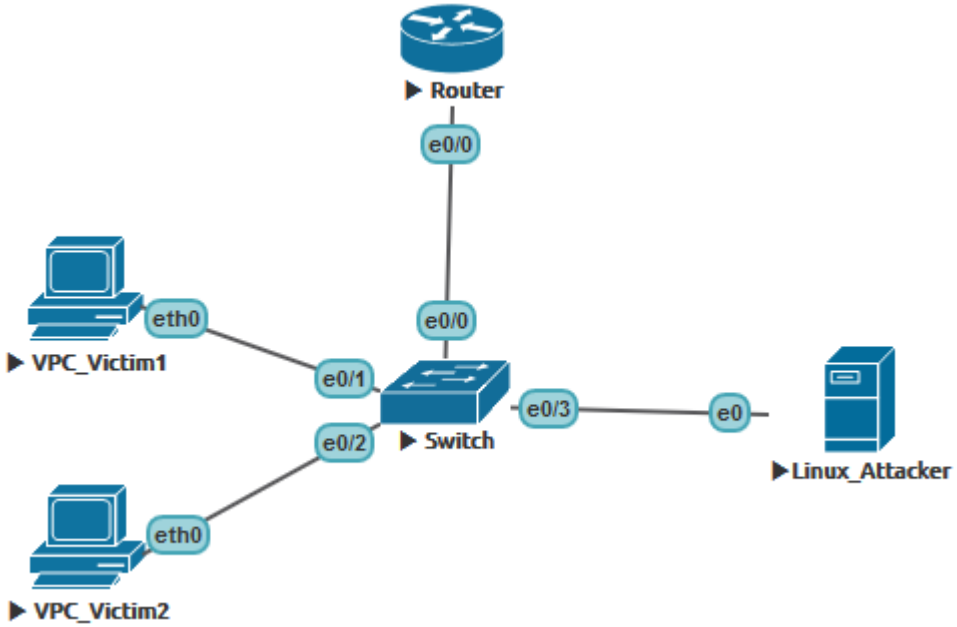
GOAL

The Dynamic Host Configuration Protocol (DHCP) is a standardized network protocol used on Internet Protocol (IP) networks. The DHCP protocol is controlled by a DHCP server that dynamically distributes network configuration parameters, such as IP addresses, for interfaces and services. A router or a residential gateway can be enabled to act as a DHCP server. A DHCP server enables computers to request IP addresses and networking parameters automatically, reducing the need for a network administrator or a user to configure these settings manually. In the absence of a DHCP server, each computer or another device (e.g., a printer) on the network needs to be statically (i.e., manually) assigned an IP address.

The goal of this scenario is to illustrate how DHCP might be compromised by performing Denial of Service attack on DHCP pool. If DHCP server runs out of pool addresses, then no new user can be enrolled in the network.

DHCP Snooping is a general countermeasure against various DHCP exploits such as DHCP DoS on the pool, or fake DHCP servers.

TOPOLOGY

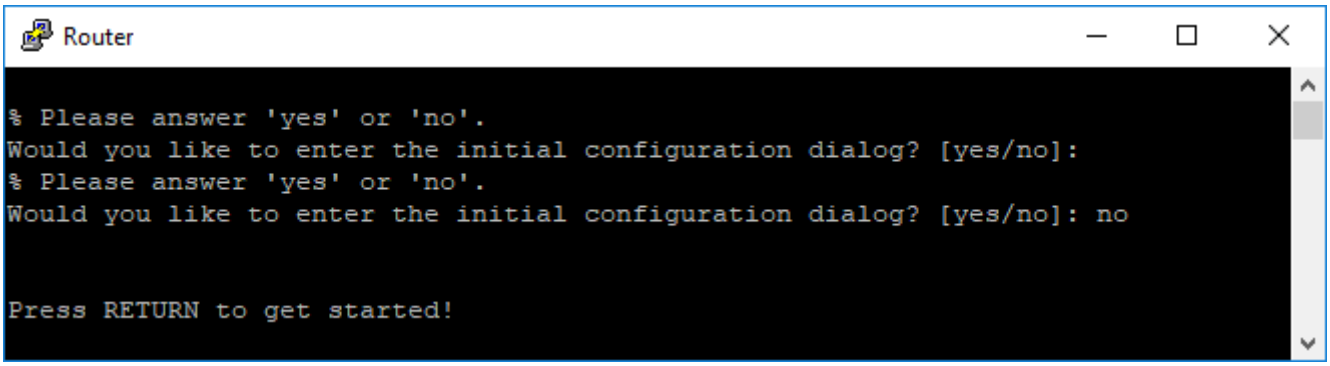


SCENARIO

1. Setup *Router* as legitimate DHCP server
2. Test DHCP on *VPC_Victim1*
3. Perform DoS on DHCP address pool
4. Spoof fake DHCP server into network
5. Deploy DHCP Snooping
6. Verify DHCP Snooping functionality

SETUP *ROUTER* AS DHCP SERVER

1. Please skip the initial wizard, you are going to configure everything manually

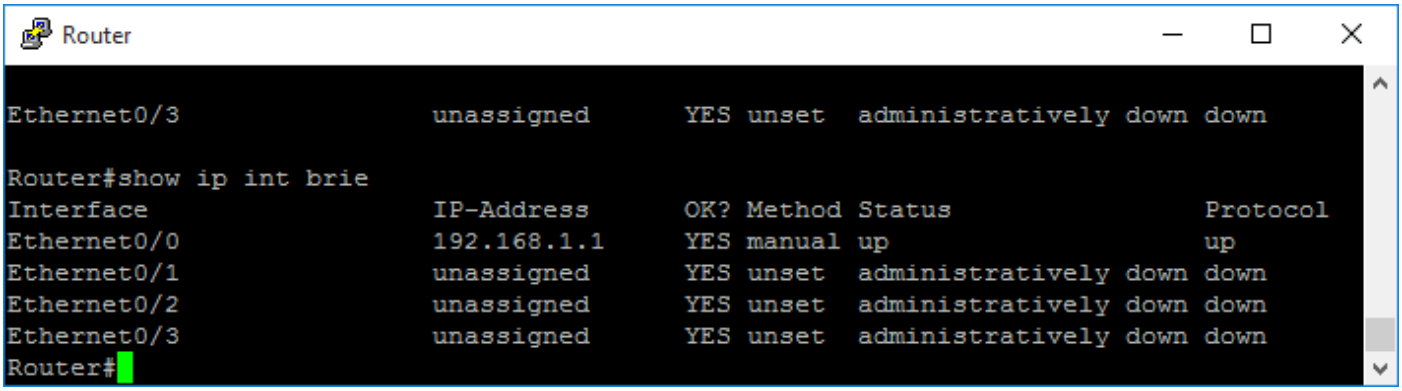


2. Enter global configuration

```
Router> enable
Router# configure terminal
```

3. Configure IP address on interface e0/0

```
Router(config)# interface e0/0
Router(config-if)# ip address 192.168.1.1 255.255.255.0
Router(config-if)# no shutdown
Router(config-if)# end
Router(config)# show ip interface brief
```



4. Create a DHCP Pool

```
Router# configure terminal
Router(config)# ip dhcp pool MYPOOL
Router(dhcp-config)# network 192.168.1.0 /24
Router(dhcp-config)# default-router 192.168.1.1
Router(dhcp-config)# dns-server 8.8.8.8
Router(dhcp-pool)# exit
Router(config)# ip dhcp exclude-address 192.168.1.1 192.168.1.99
```

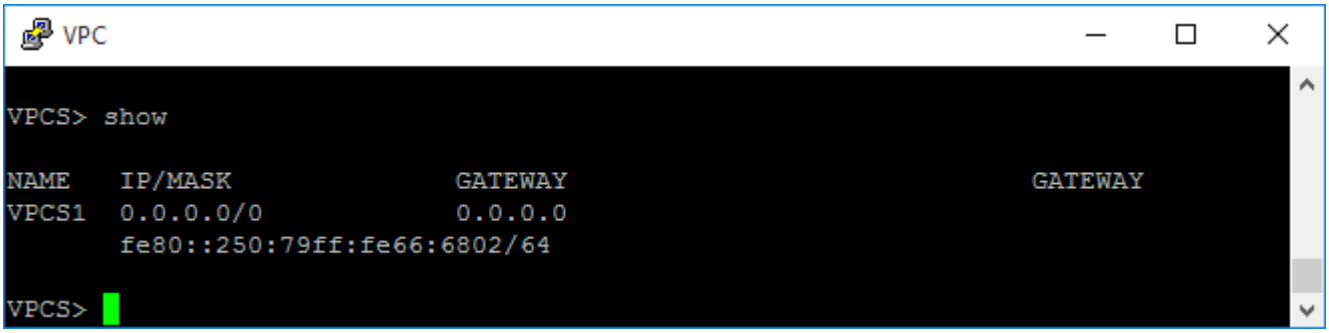
5. Enable DHCP debug logging

```
Router(config)# end
Router# debug ip dhcp server events
```

TEST CONNECTIVITY ON *VPC_VICTIM1*

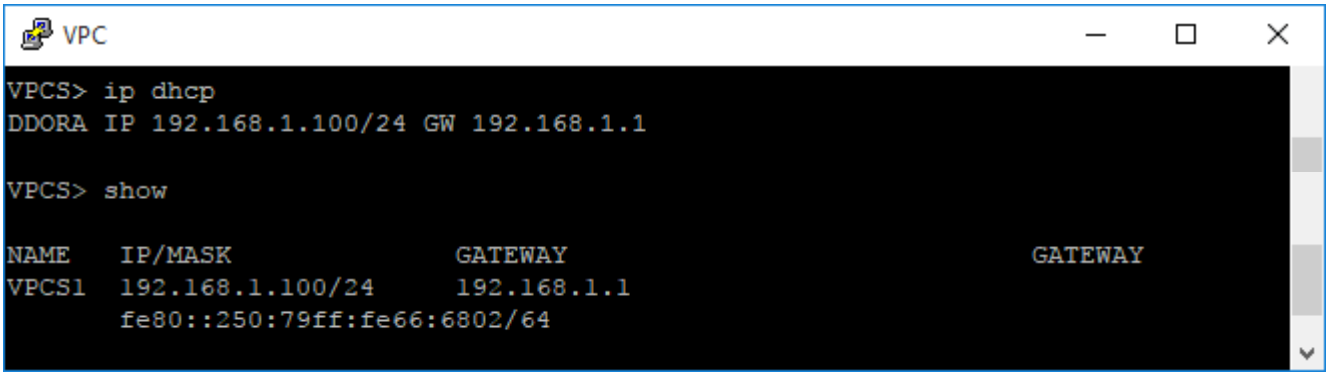
1. *VPC_Victim1* does not have any address assigned yet,

   VPCS> **show**

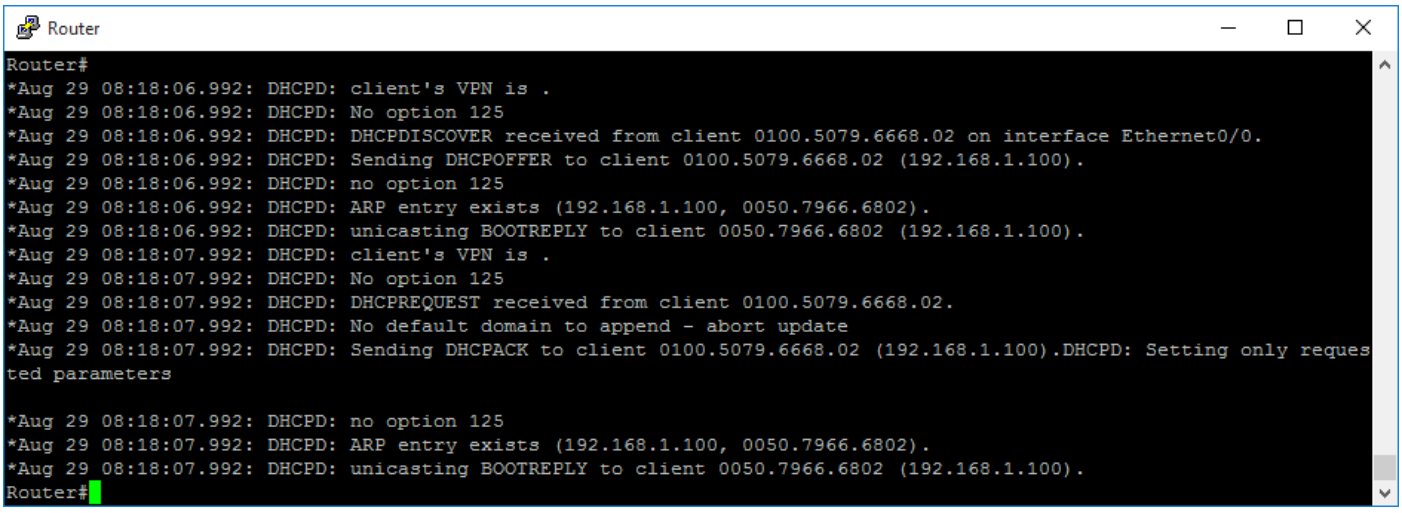


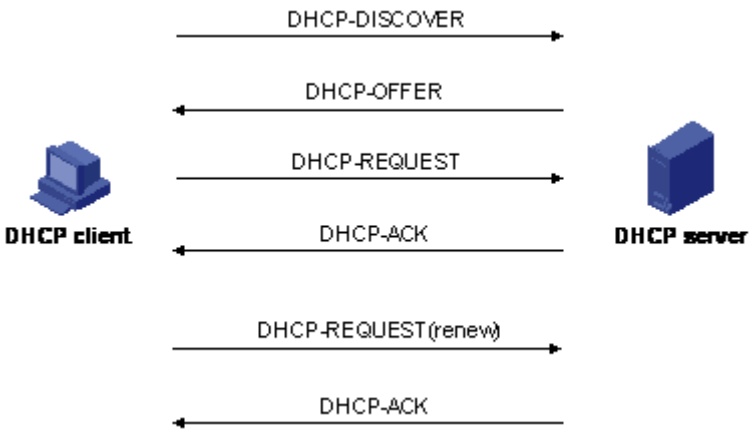
2. Ask for DHCP lease, issue command **ip dhcp**

   VPCS> **ip dhcp**

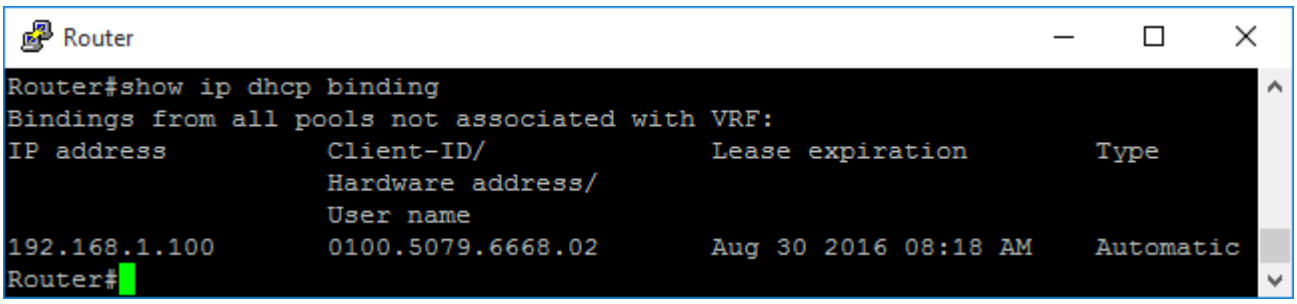


3. Address is assigned, you can see packet exchange in Router's console window



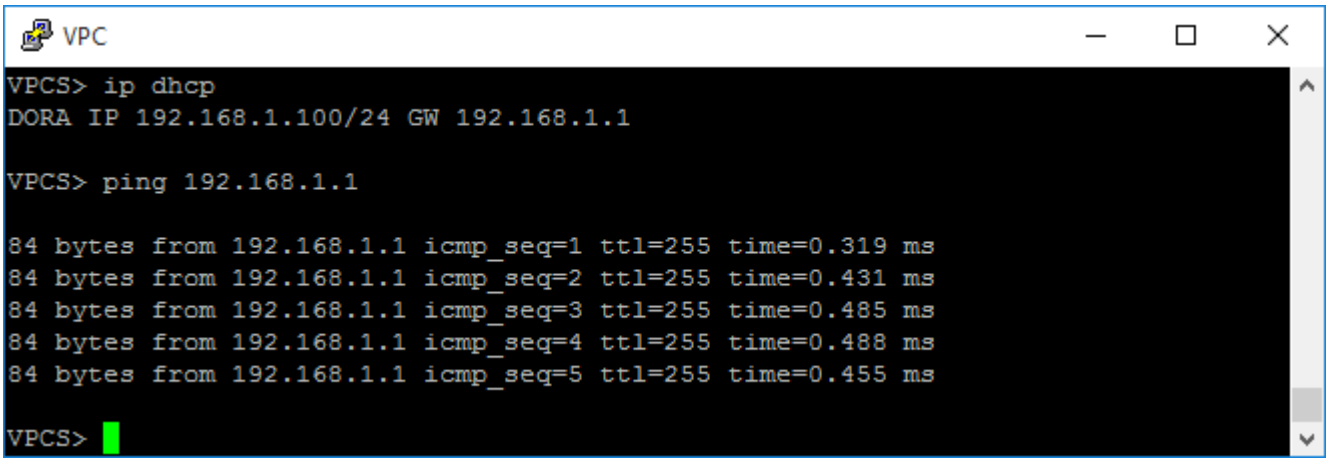


4. Moreover, *Router* bound MAC address to assigned IP address of client *VPC_Victim1*

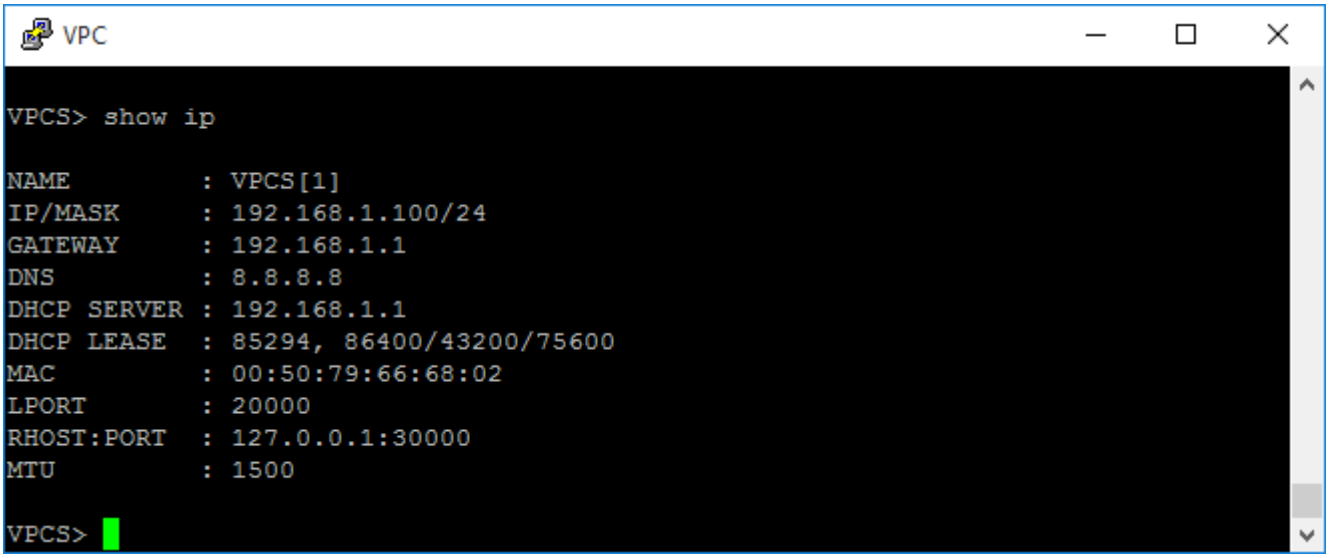


5. Host is able to reach default gateway

VPCS> **ping 192.168.1.1**



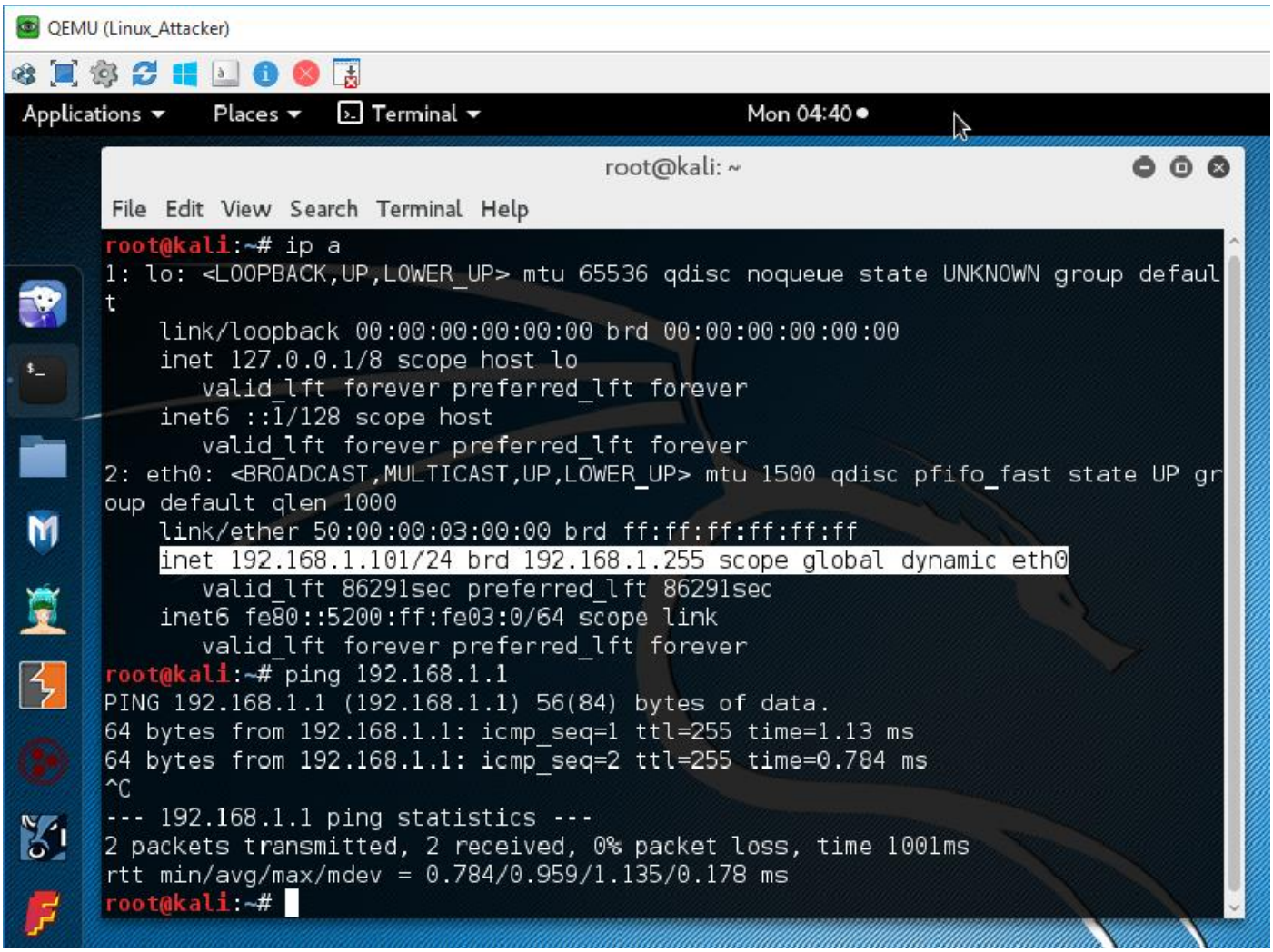
VPCS> **show ip**

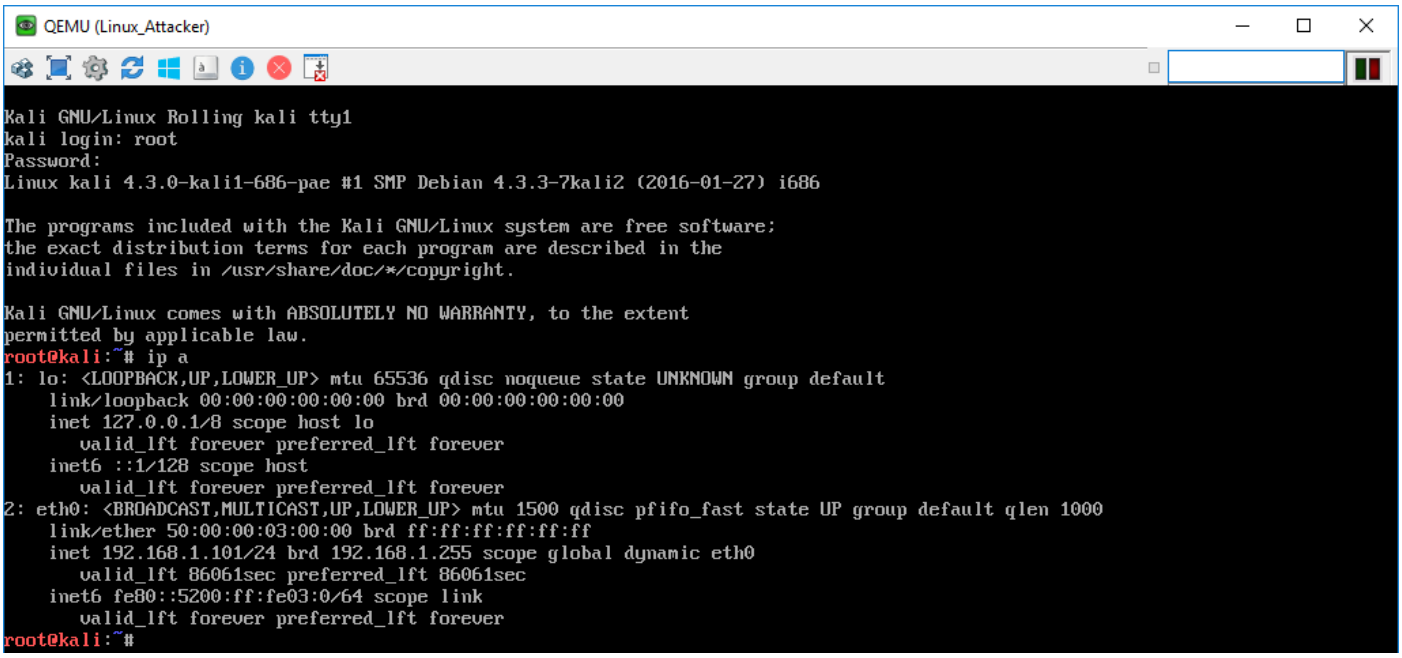


PERFORM DISCOVER DOS ATTACK ON *LINUX_ATTACKER* AND DEPLETE DHCP SERVER'S POOL

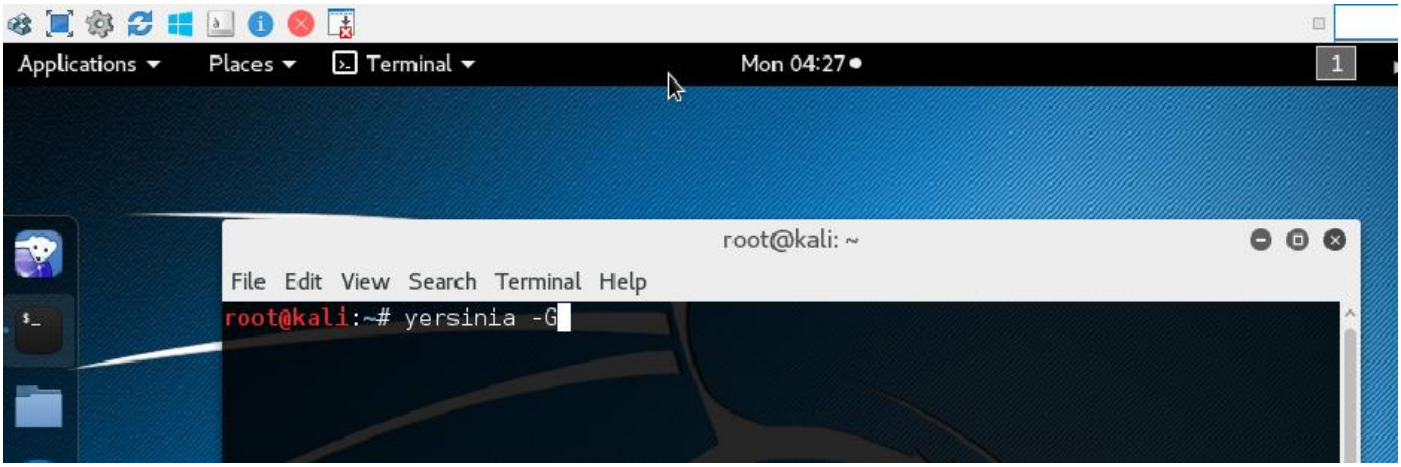
1. Turn on *Linux_Attacker*
2. Log in to operating system by typing username "root", password "toor". Use either GUI, or CLI (by pressing Ctrl+Alt+F1)
3. Open terminal
4. Check the DHCP and IP connectivity with the *Router*

```
root@kali:~# ip a
root@kali:~# ping 192.168.1.1
```

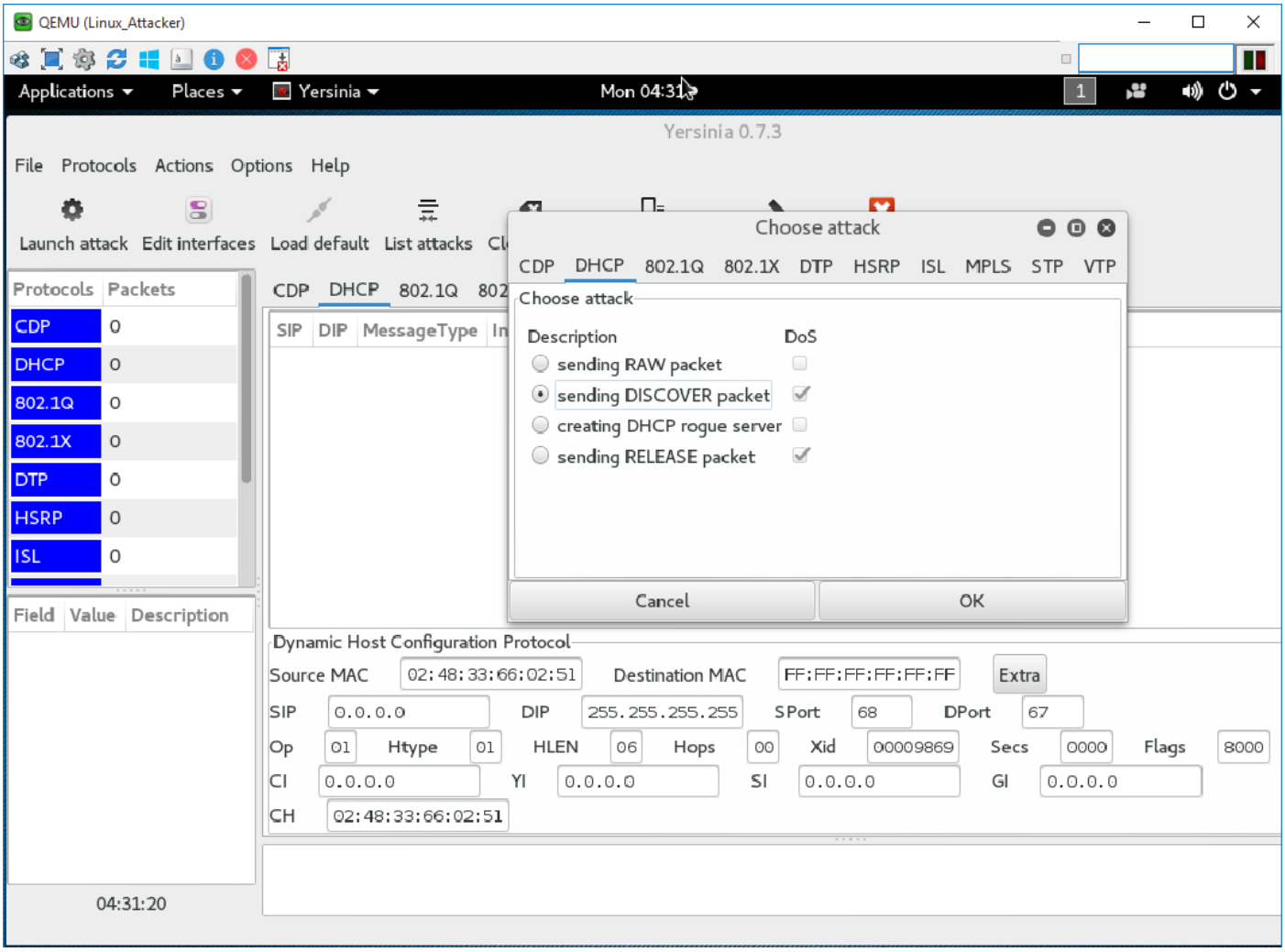




5. Launch Yersinia application by typing **`yersinia -G`** (for GUI)

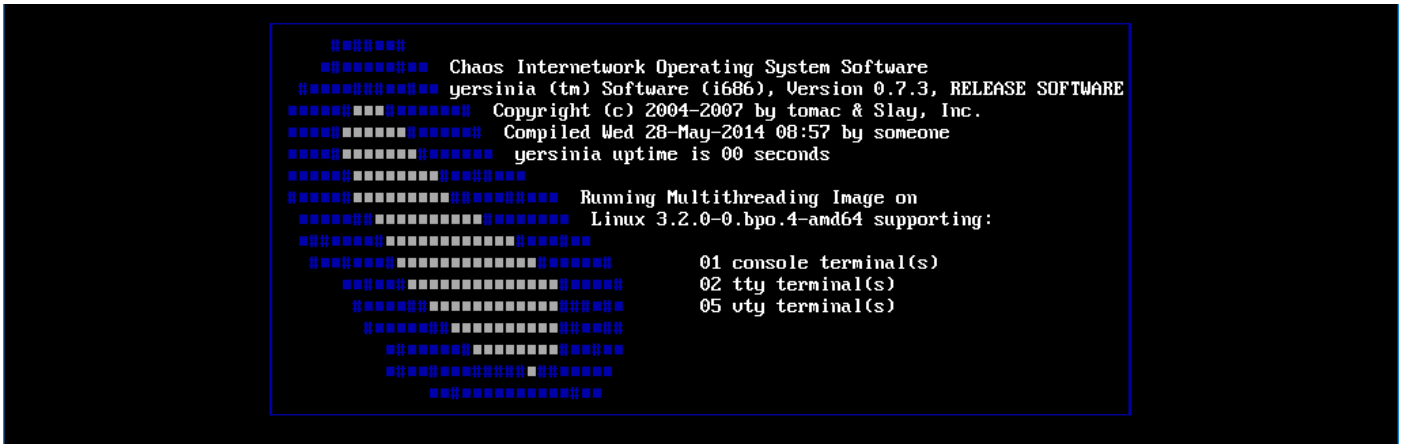


6. Close the warning message (move around window in order to reach OK button focus).
7. Change tab to “DHCP” and push “Launch attack” button.
8. Choose “sending DISCOVER packets” in dialog window

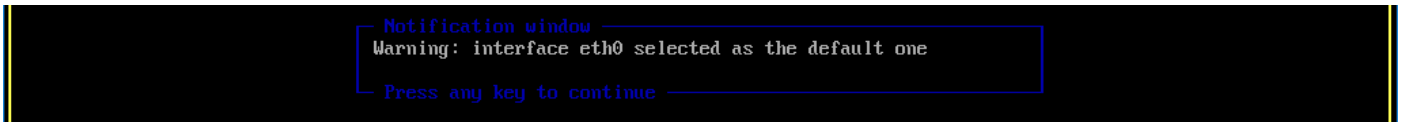


9. Click “OK”, which starts the attack where *Linux_Attacker* will spoof DHCP Discover messages to the network

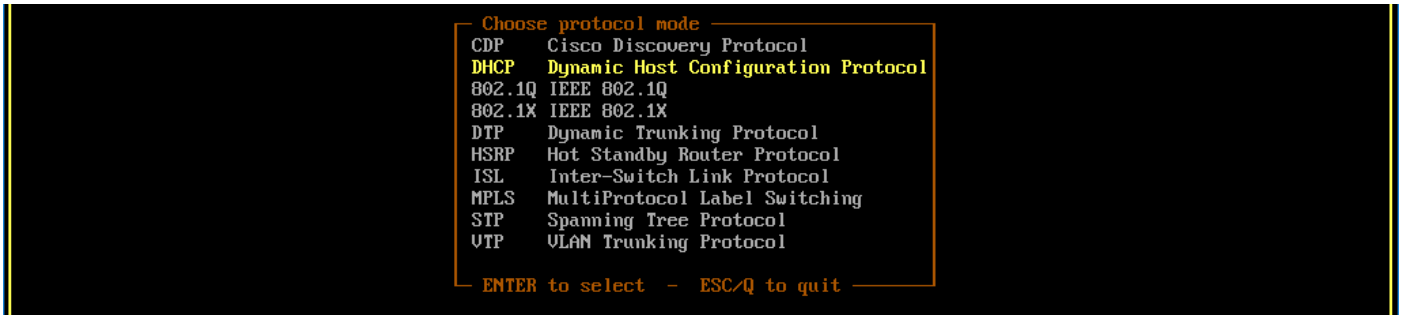
5. Launch Yersinia application by typing **`yersinia -I`** (for CLI)



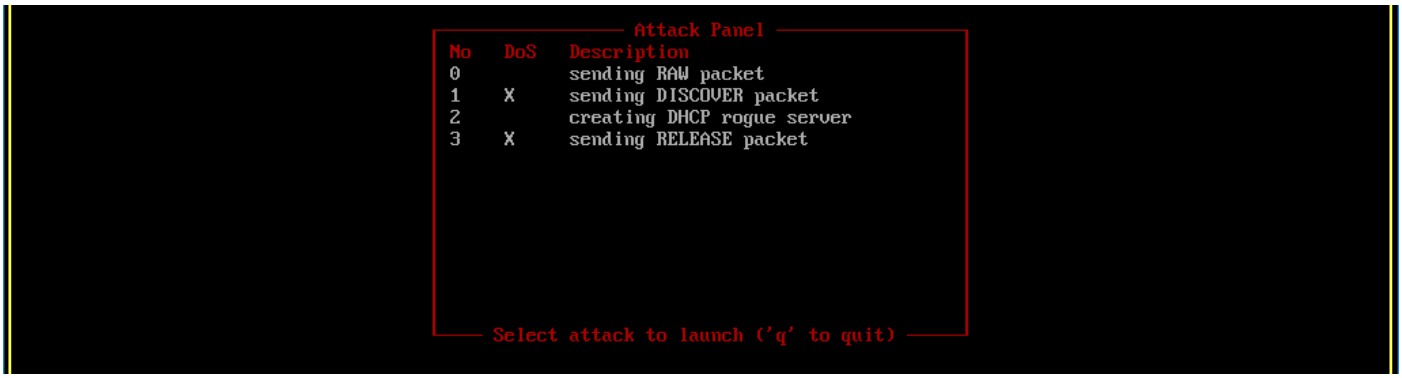
6. Default yersinia interface is eth0



7. Type **`g`** and choose DHCP tab

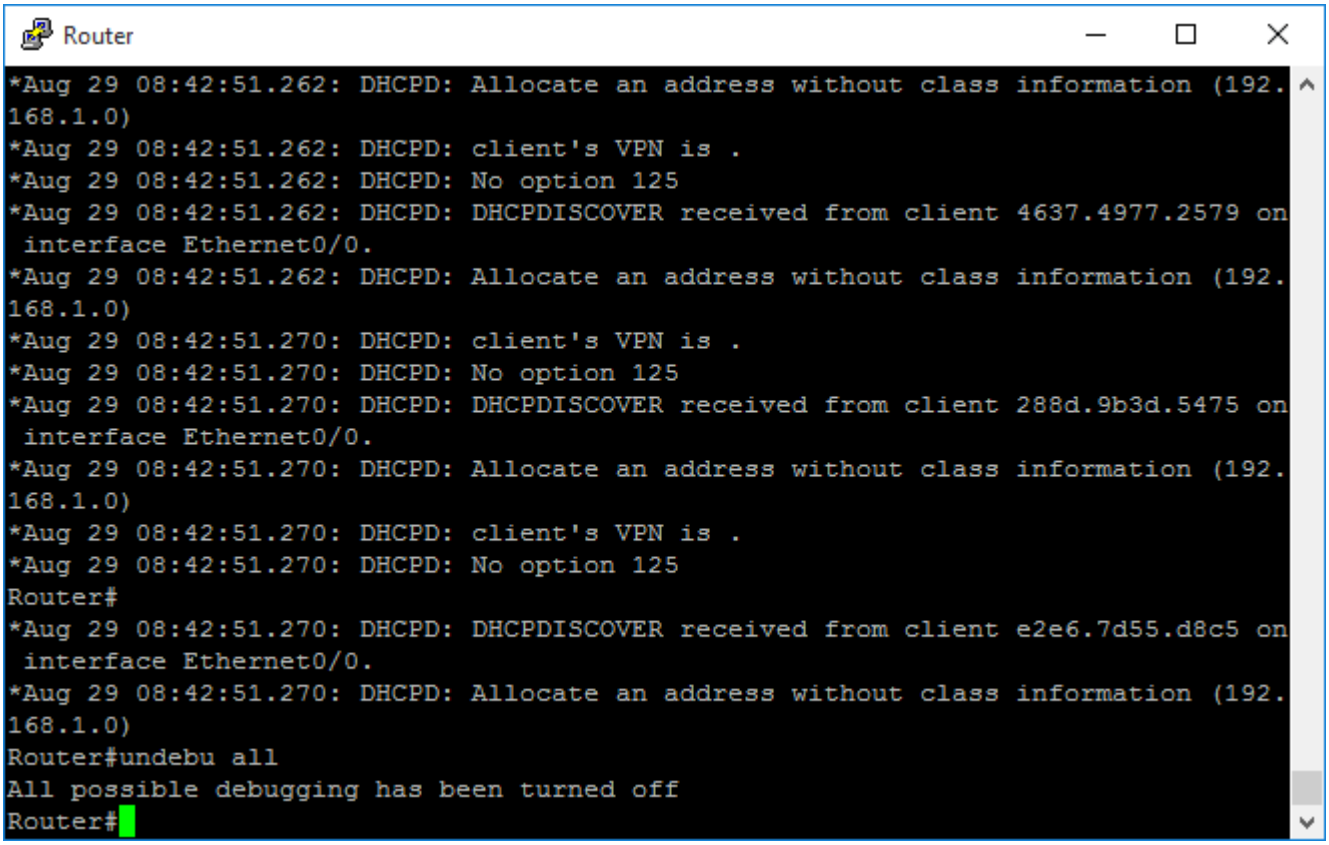


8. Type **`x`** to open available attacks dialog. Choose “sending DISCOVER packets” by typing **`1`**.



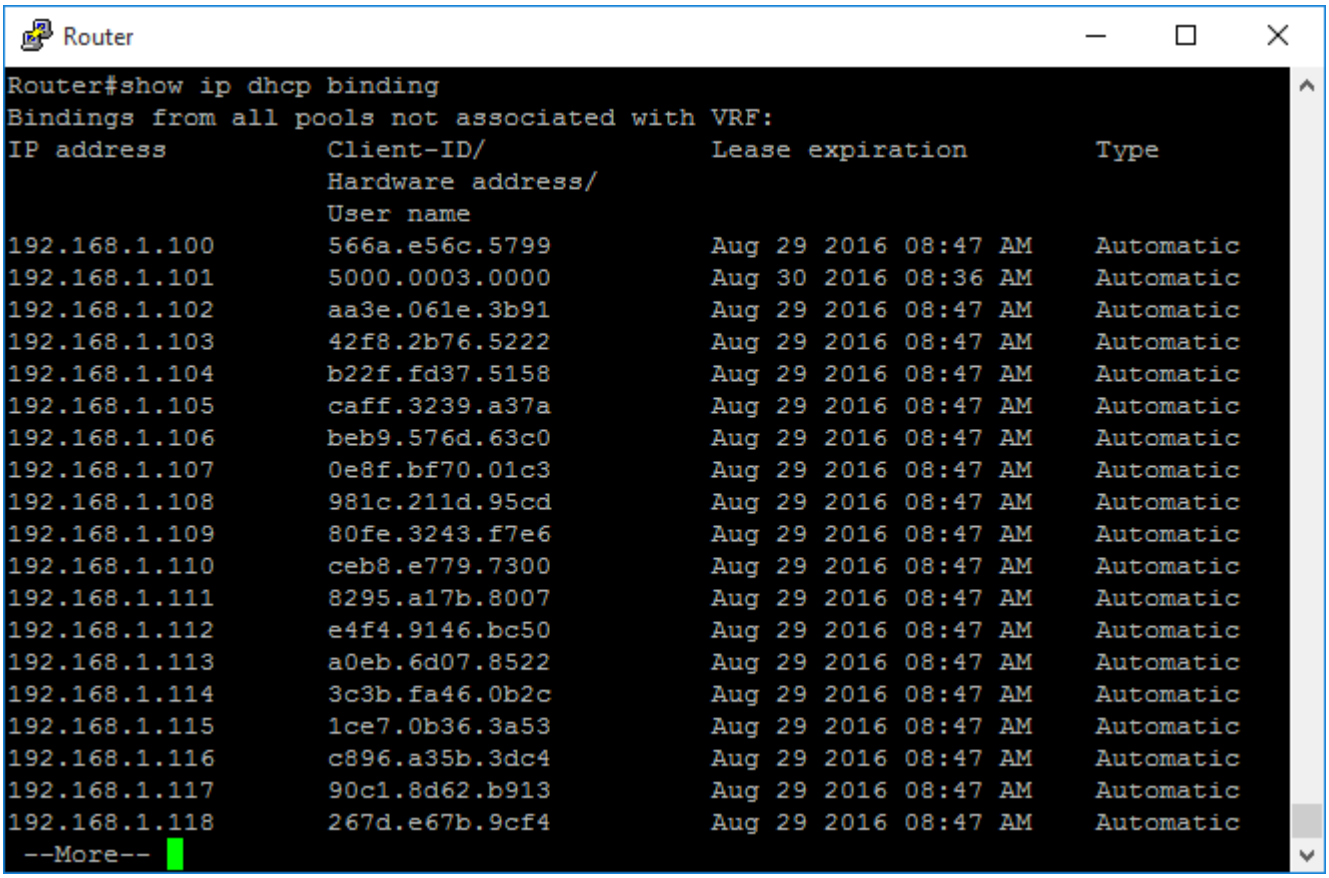
9. This starts the attack where *Linux_Attacker* will spoof DHCP Discover messages to the network

10. Router's console is overloaded with debug messages, stop logging by typing blindly to console **`undebug all`**



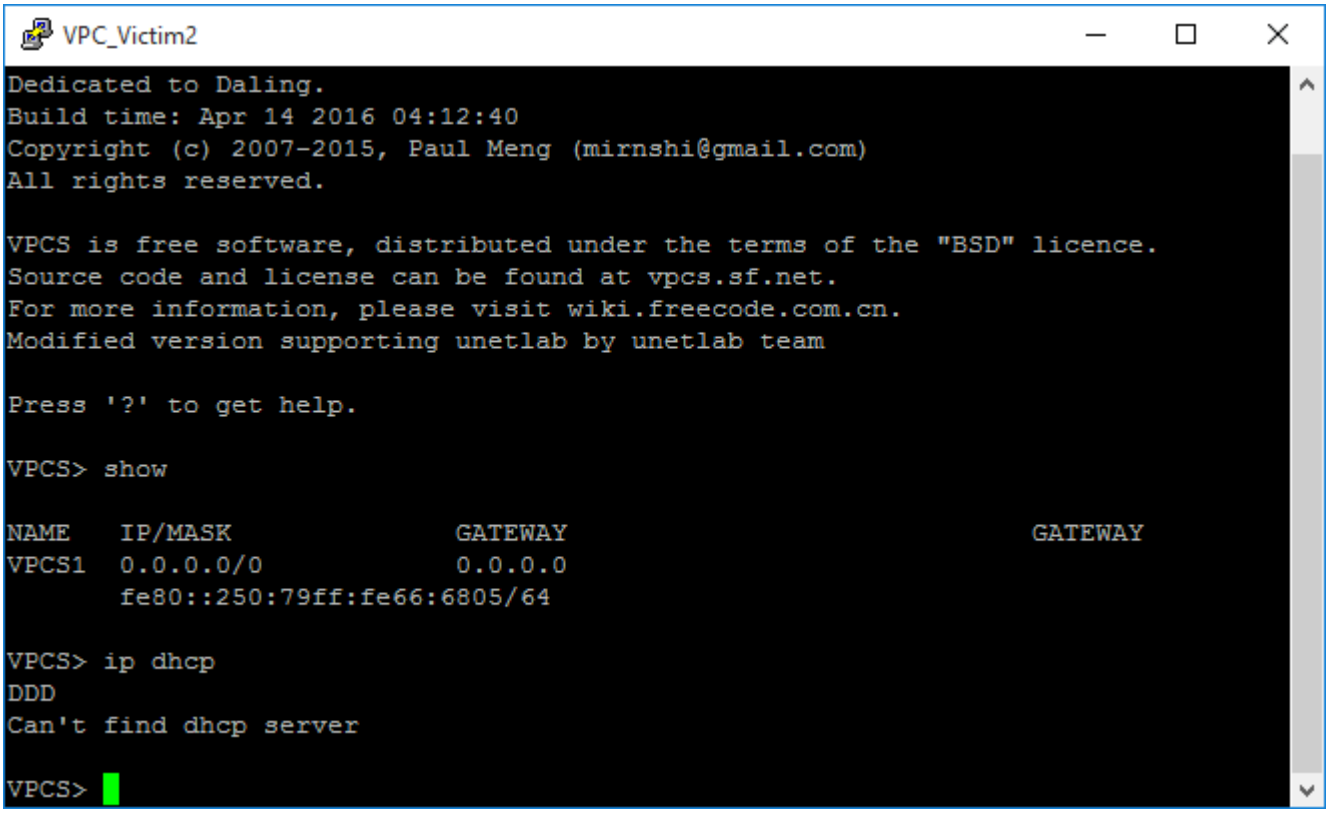
11. Observe how *Router*'s assignment pool is depleted (all addresses assigned)

```
Router# show ip dhcp binding
```

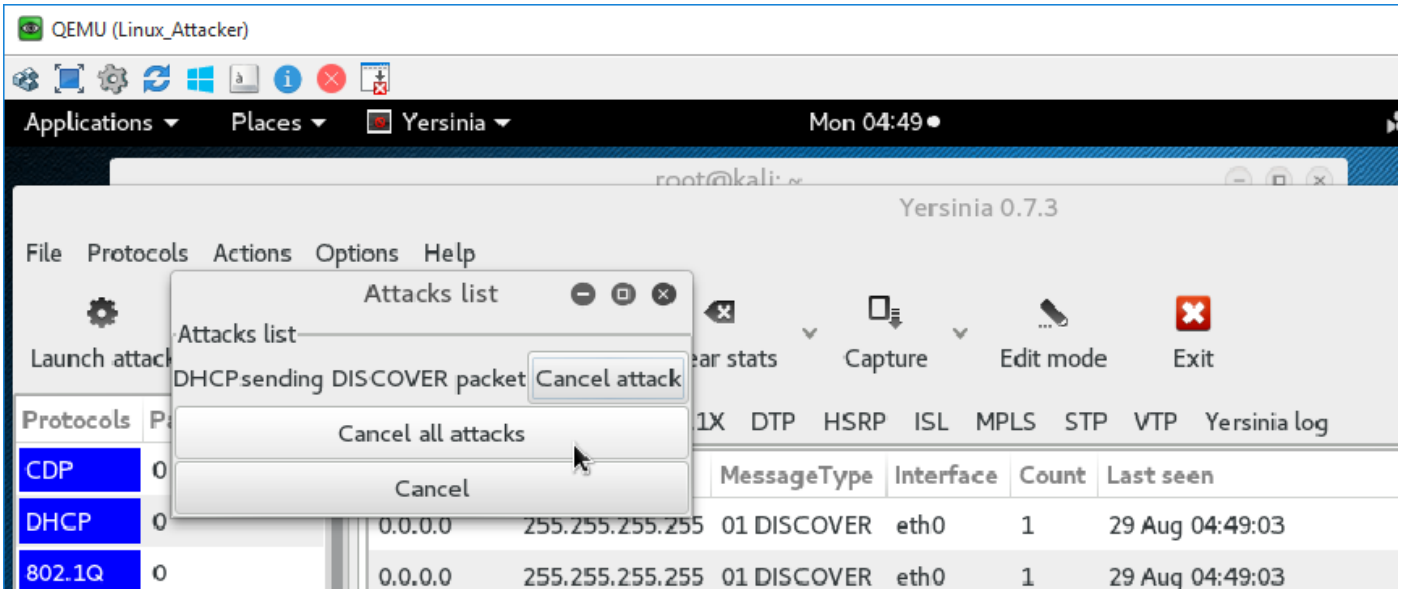


12. Because there are no addresses left in the pool, *VPC_Victim2* is unable to obtain any address.

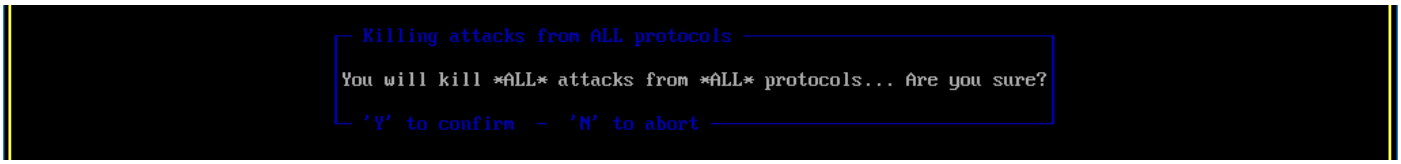
```
VPCS> show
VPCS> ip dhcp
```



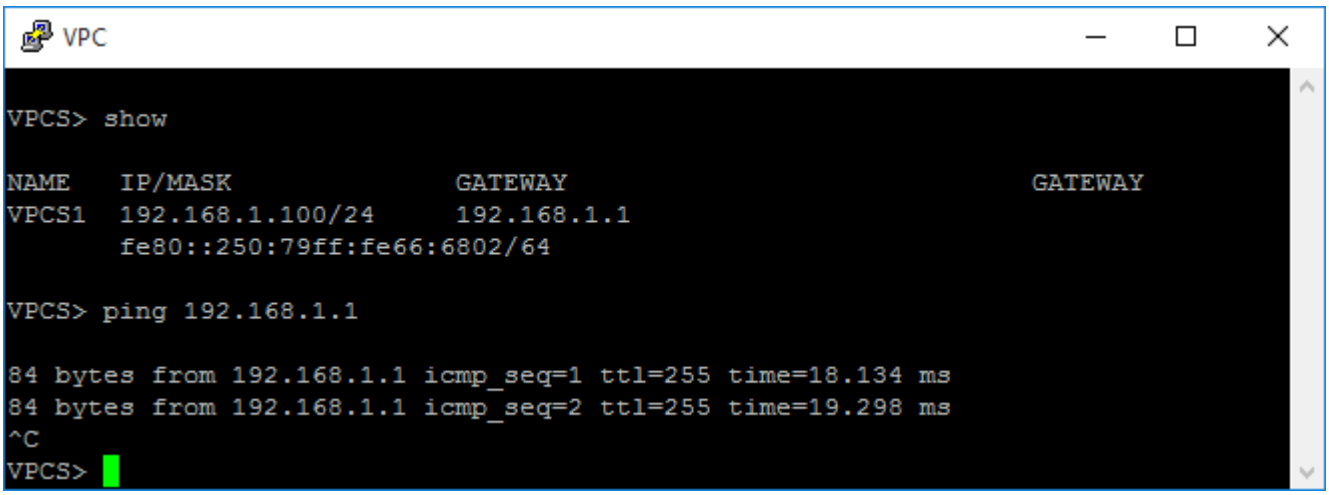
13. Cancel attack on *Linux_Attacker* by:
    a. pushing “List attacks” button and hitting “Cancel all attacks” for GUI



    b. typing **K** and confirming cancel with **Y** for CLI

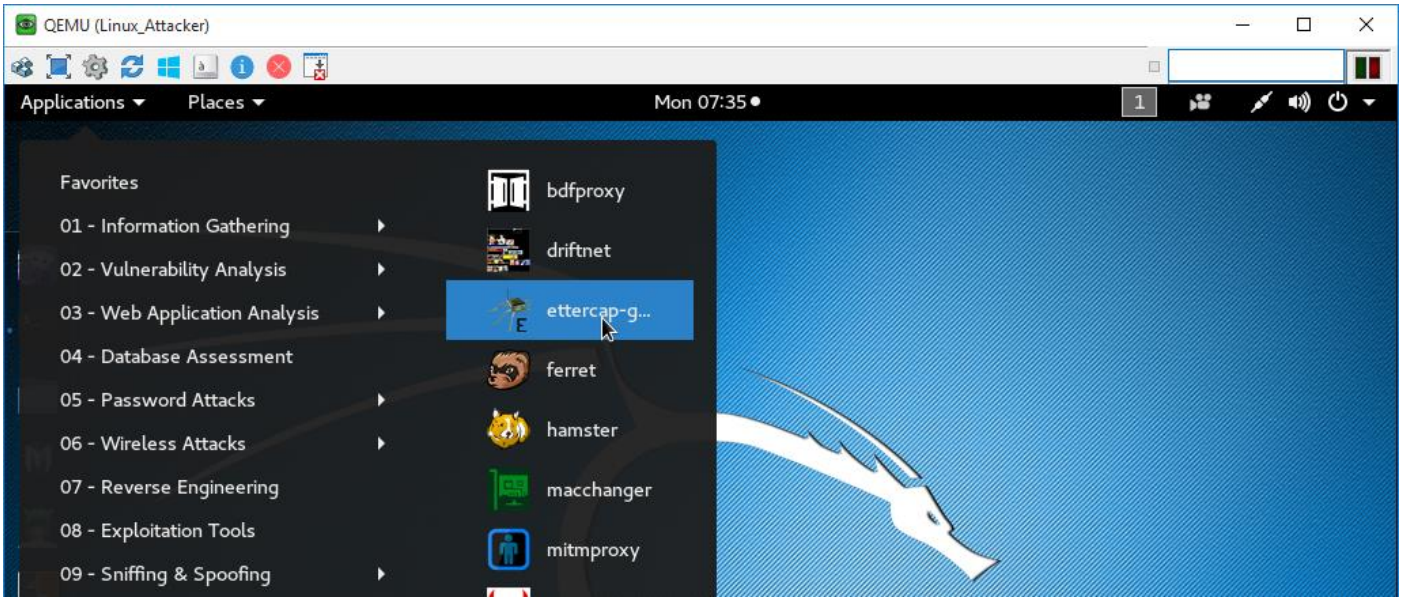


14. Nevertheless, *VPC_Victim1* with already assigned address is able to reach *Router*

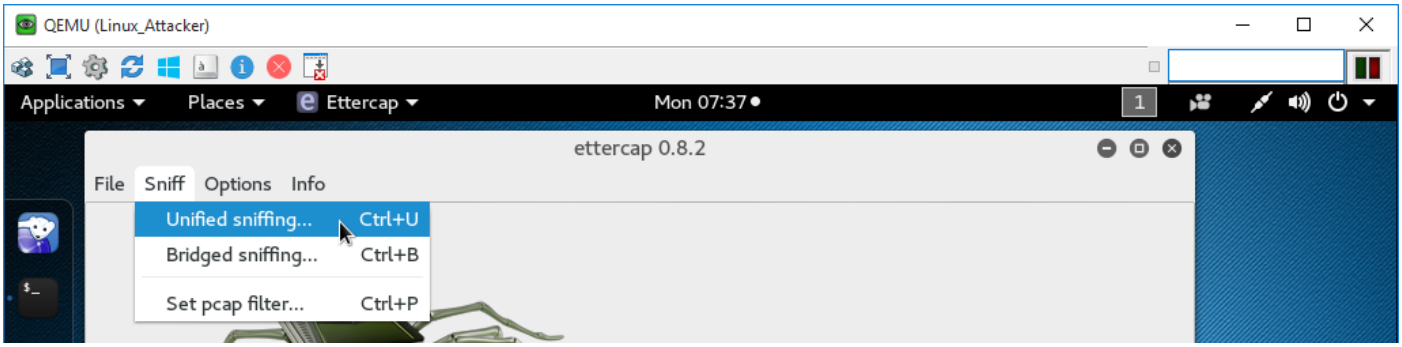


ESTABLISH FAKE DHCP SERVER ON *LINUX_ATTACKER*

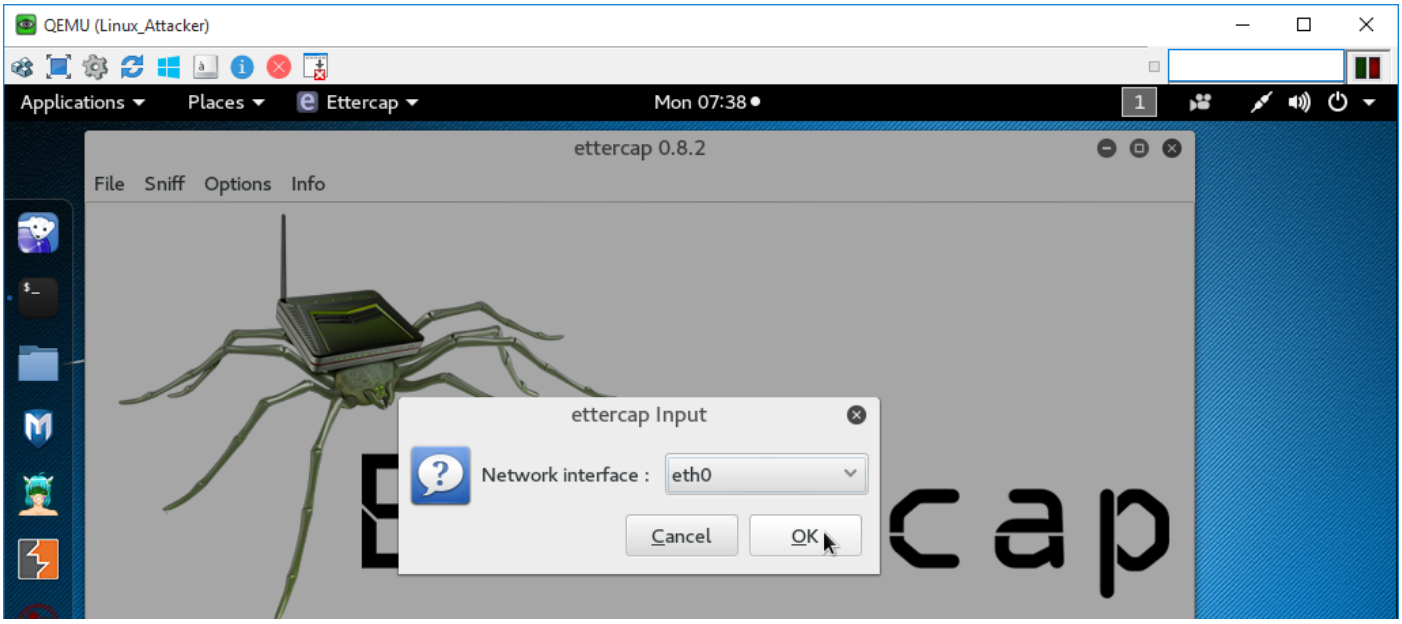
1. Switch back to GUI if necessary (by typing Ctrl+Alt+F7). Launch Ettercap tool on *Linux_Attacker*, click on “Applications”, chose “09 – Sniffing & Spoofing“.



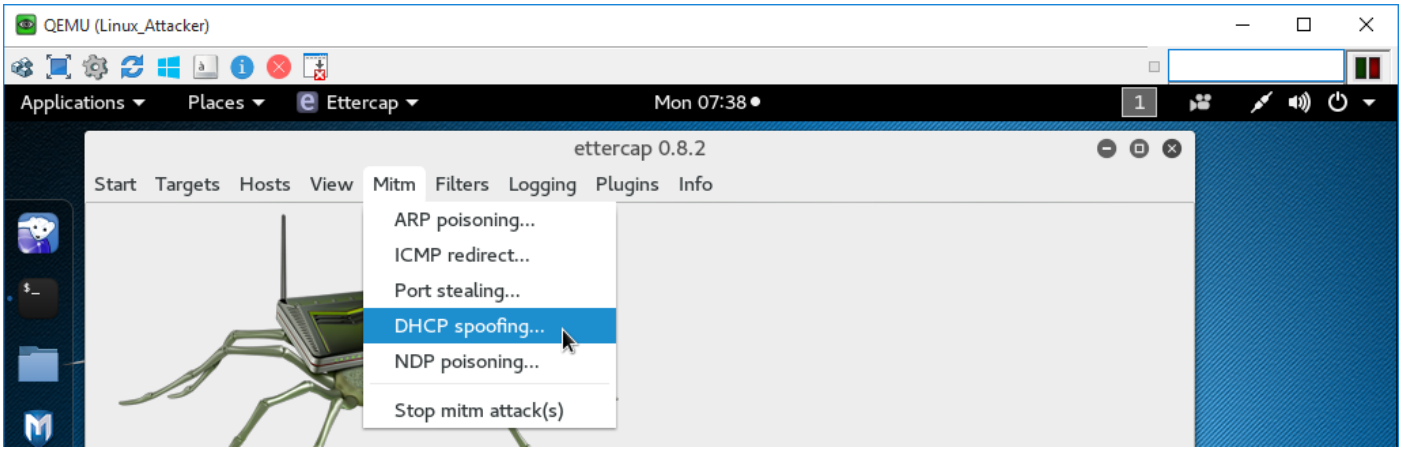
2. Initiate unified sniffing from network interface card by pressing Ctrl+U



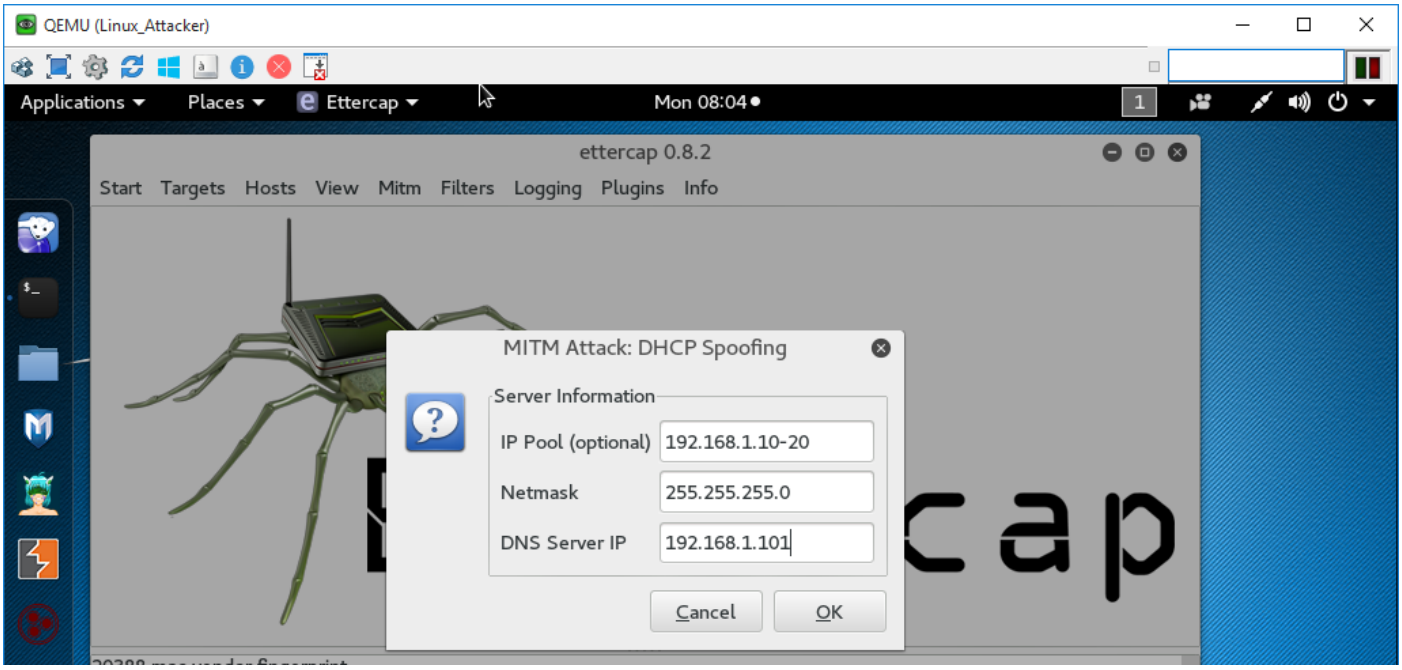
3. Pick eth0 interface and click “OK”



4. From the selection of “Mitm” attacks, choose “DHCP Spoofing”

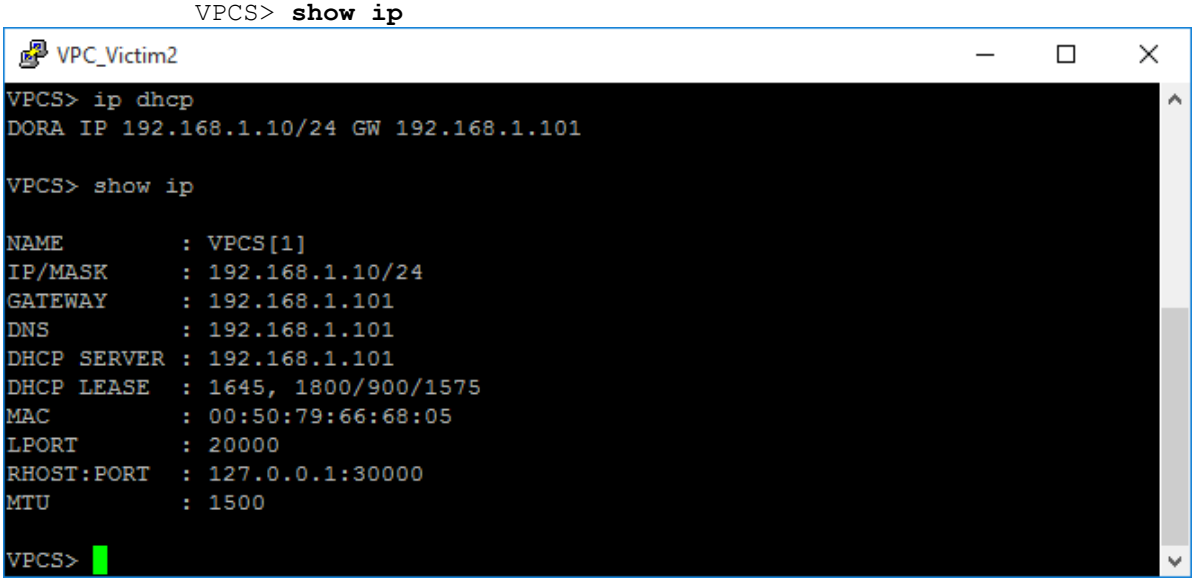


5. Configure fake DHCP server (by specifying pool 192.168.1.10-20, subnet mask 255.255.255.0 and DNS server as attacker's IP address 192.168.1.101, default gateway is automatically *Linux_Attacker*) and initiate attack by pressing "OK" button



6. Ask for address lease on *VPC_Victim2*

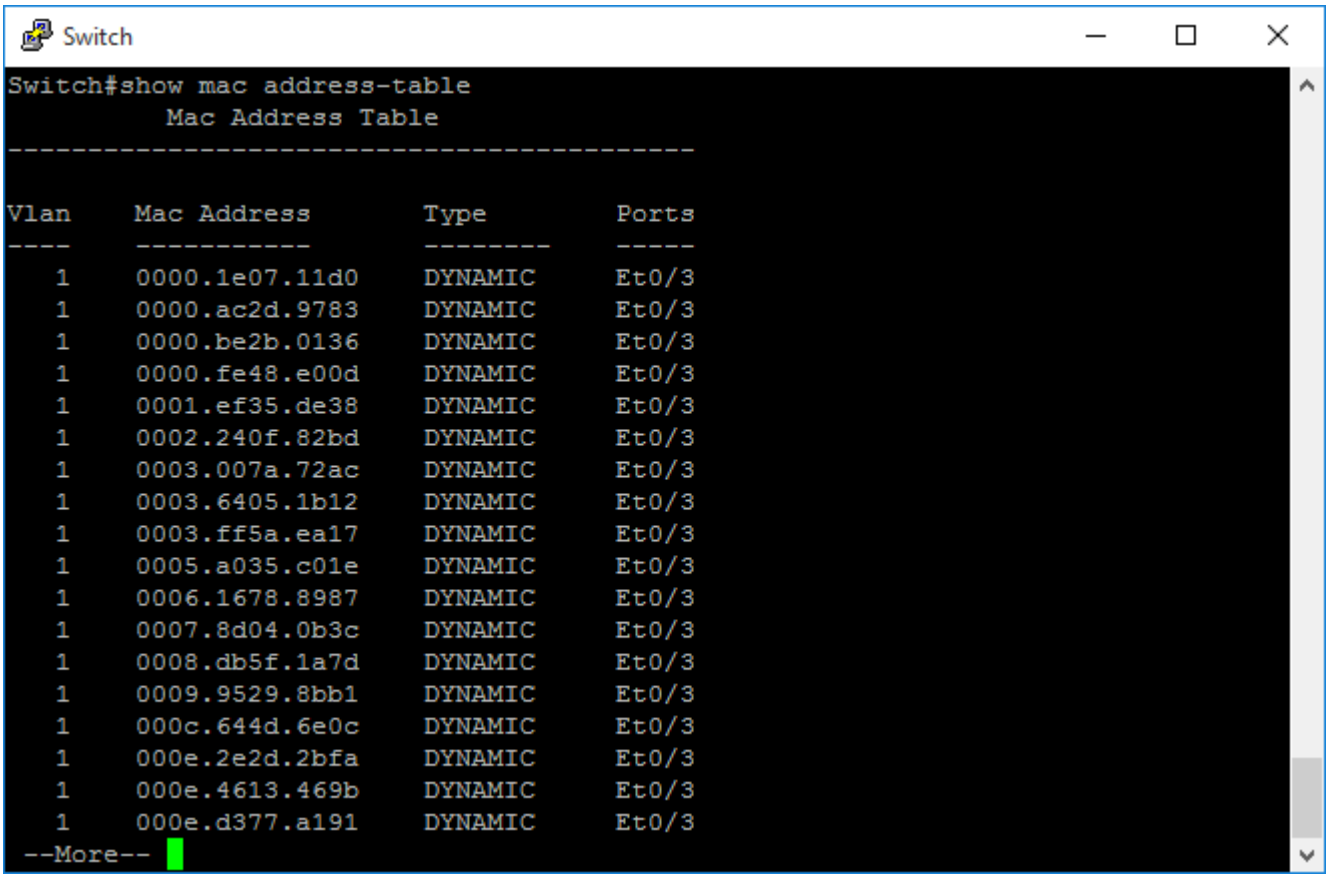
```
VPCS> ip dhcp
VPCS> show ip
```



7. *VPC_Victim2* is using illegitimate IP address. Moreover, it's default gateway and DNS server is *Linux_Attacker*. Hence, *Linux_Attacker* effectively acts as man-in-the-middle for non-LAN traffic and DNS resolution

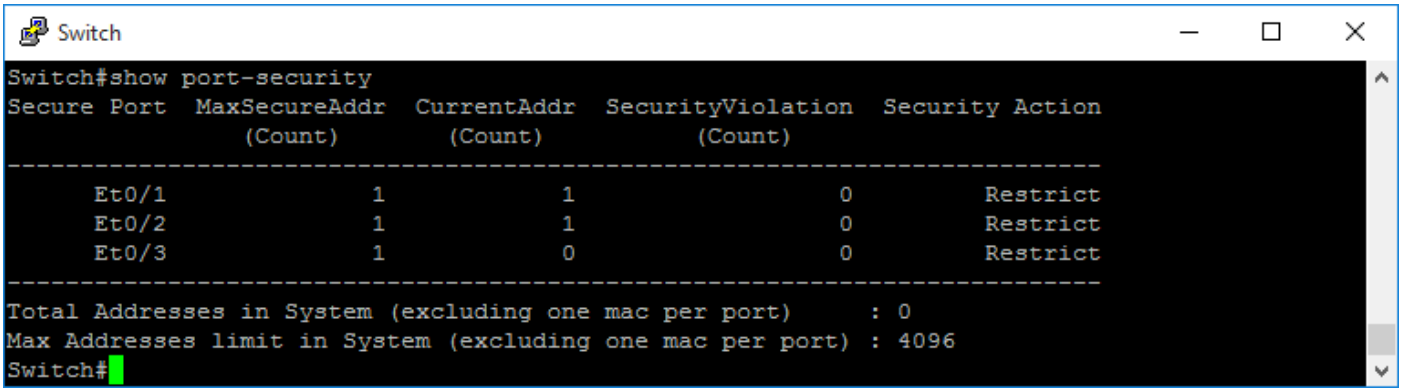
DEPLOY DHCP SNOOPING

1. Check CAM table of *Switch*, because employing PortSecurity would also help a lot for this type of attack



2. Hence, deploy PortSecurity on client's port allowing only single MAC address to be present and any other traffic would be blocked

```
Switch> enable
Switch# configure enable
Switch(config)# interface range e0/1-3
Switch(config-if)# switchport mode access
Switch(config-if)# switchport port-security
Switch(config-if)# switchport port-security maximum 1
Switch(config-if)# switchport port-security violation restrict
Switch(config-if)# exit
Switch(config)# do show port-security
```



3. Configure DHCP Snooping for all VLANs on the switch (which is currently just default VLAN 1)

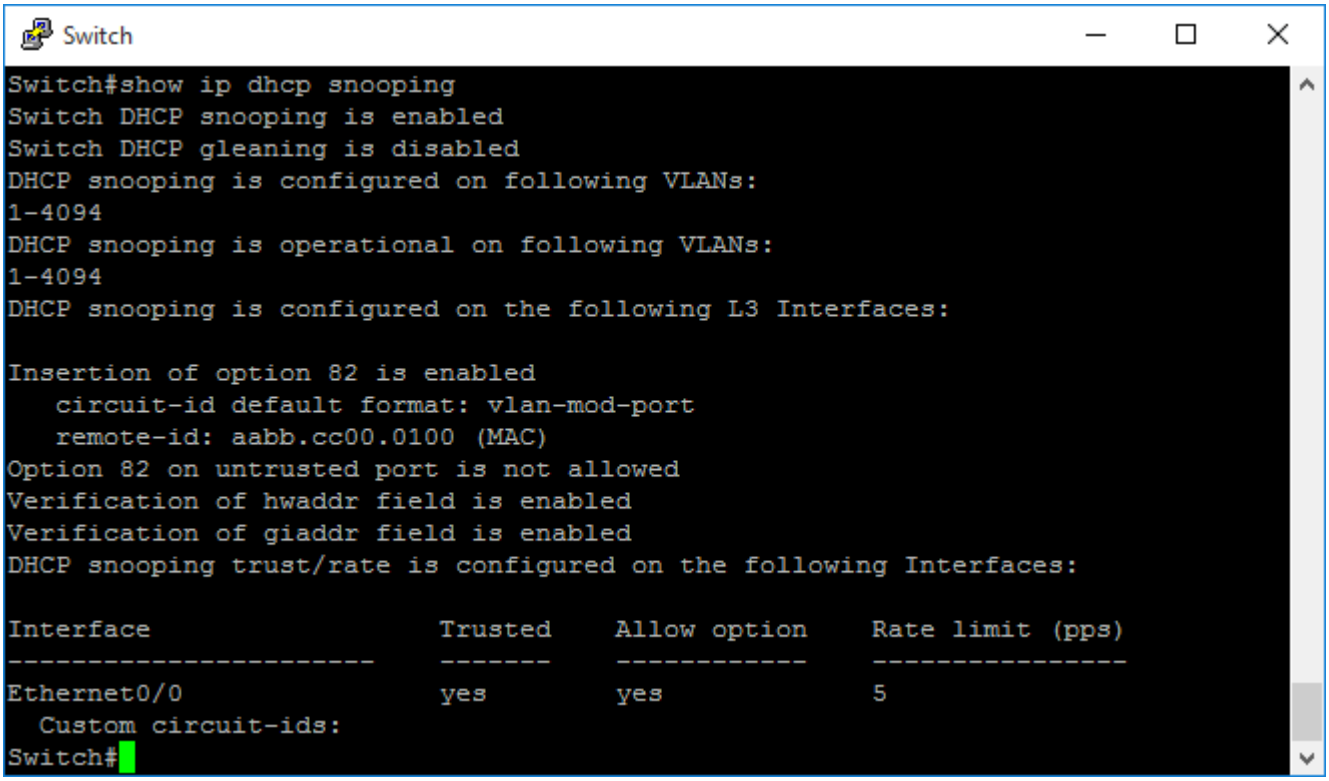
```
Switch(config)# ip dhcp snooping
Switch(config)# ip dhcp snooping vlan 1-4094
```

4. Mark *Switch* interface as trusted for DHCP snooping, which means that behind this port is DHCP router

```
Switch(config)# interface e0/0
Switch(config-if)# ip dhcp snooping trust
Switch(config-if)# ip dhcp snooping limit rate 5
```

5. Verify configuration on *Switch*

```
Switch(config)# end
Switch# show ip dhcp snooping
```

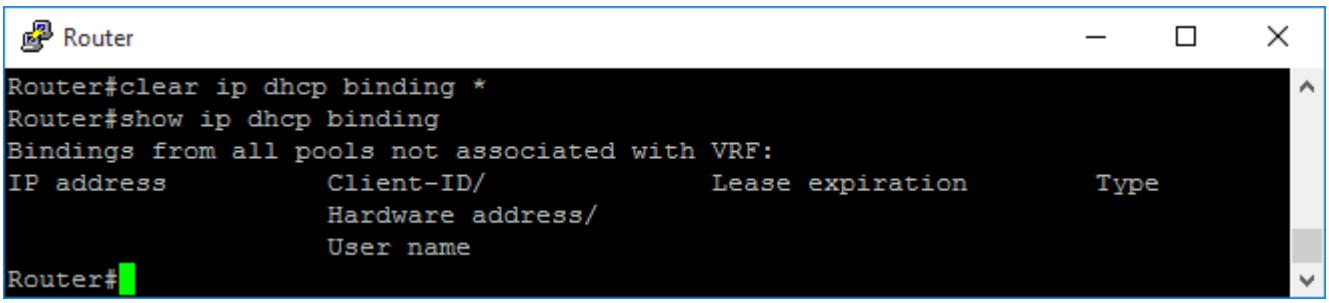


6. Configure DHCP Snooping on *Router*

```
Router# configure terminal
Router(config)# ip dhcp relay information trust-all
Router(config)# end
```

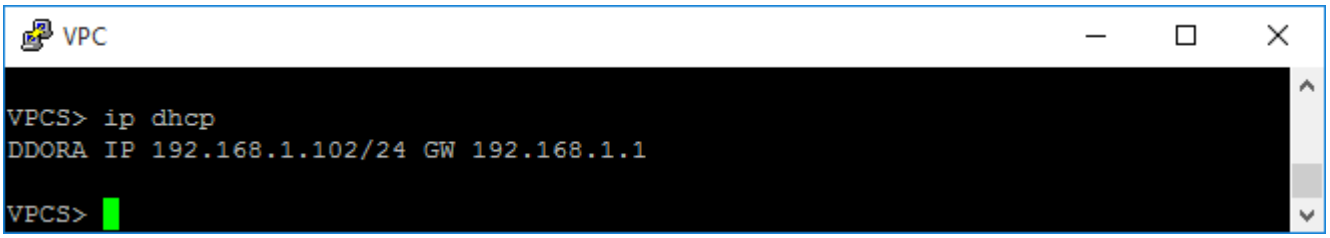
7. Clear DHCP address bindings on *Router*

```
Router# clear ip dhcp bindings *
Router# clear ip dhcp remembered bindings *
Router# show ip dhcp bindings
```

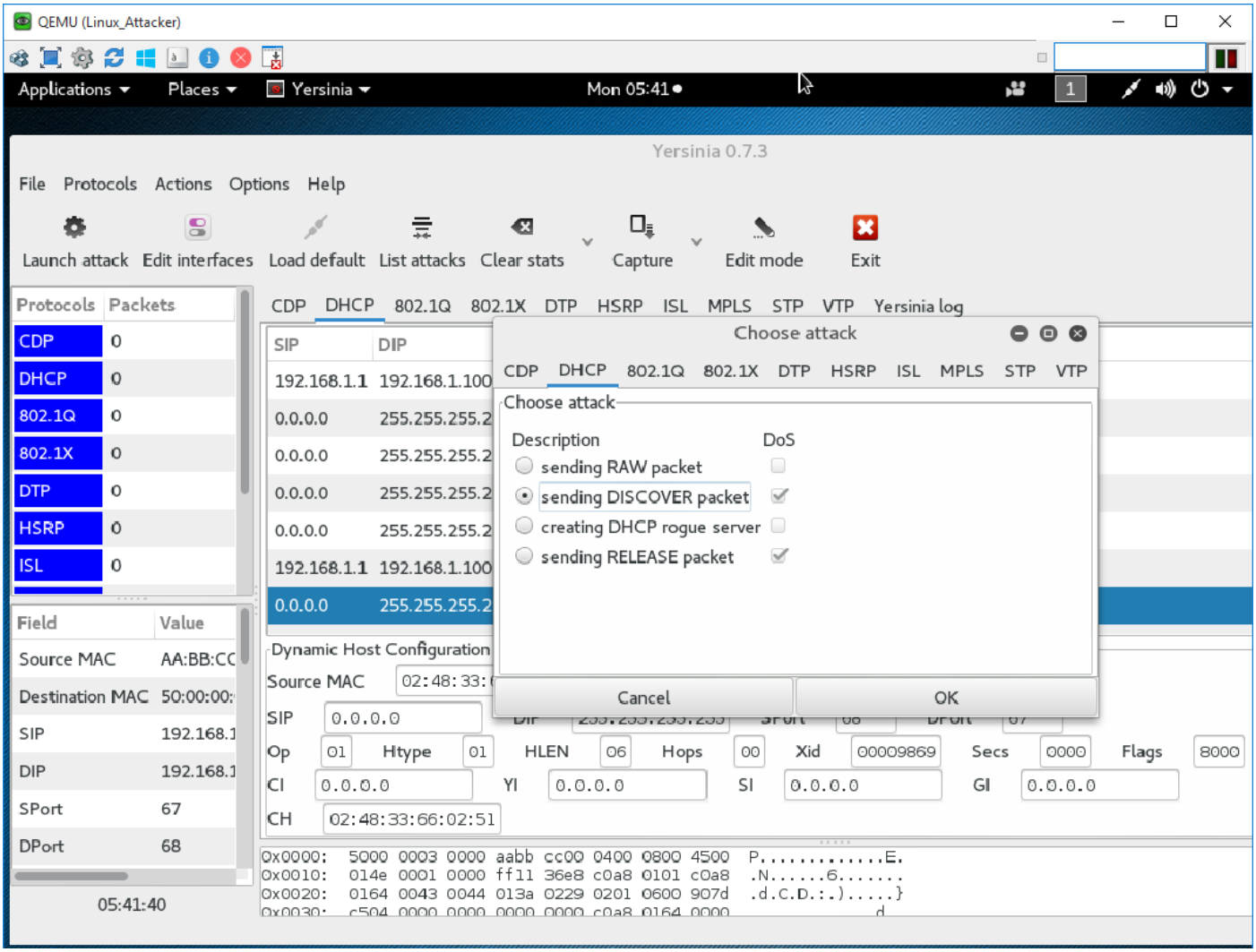


VERIFY DHCP SNOOPING OPERATION

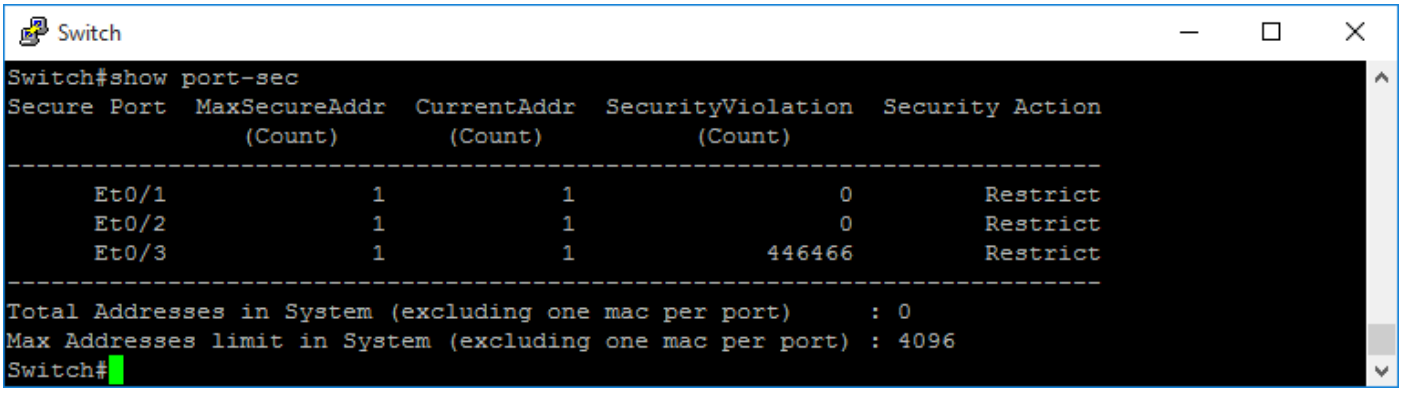
1. Renew IP address leases on *VPC_Victim1*



2. Perform attack on *Linux_Attacker*

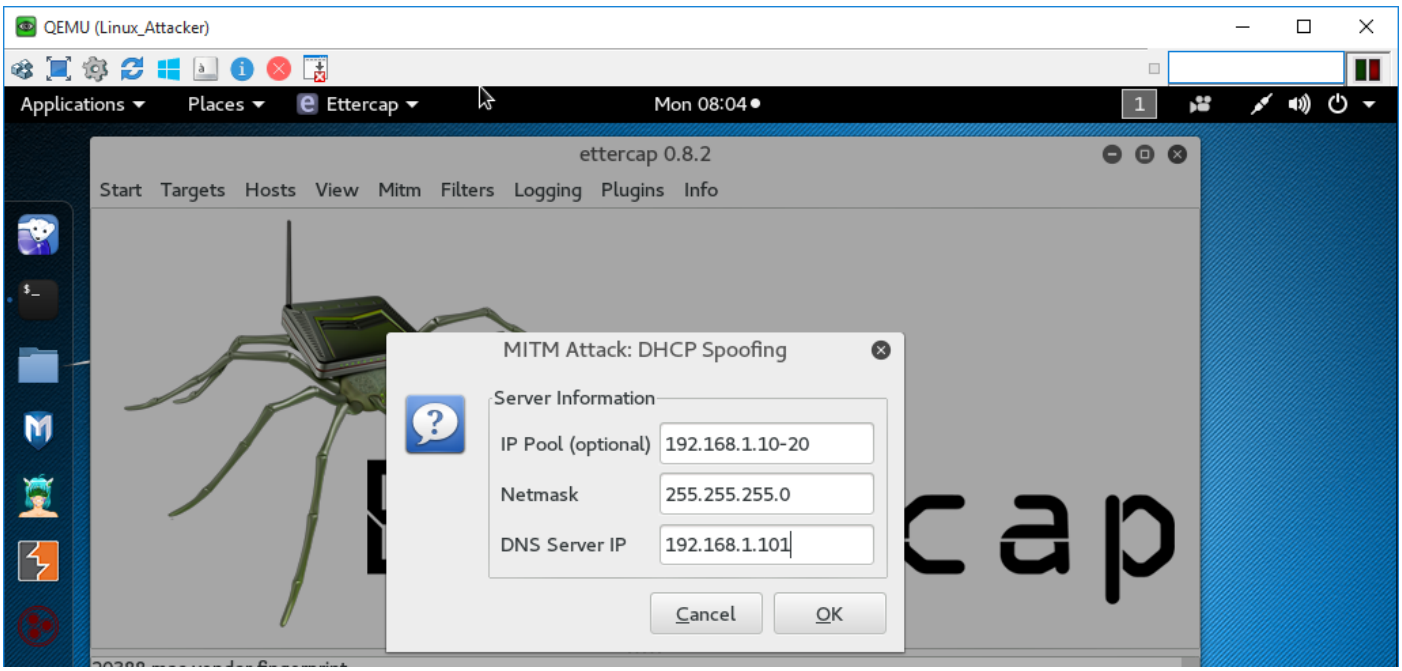


3. PortSecurity protects *Switch* and *Router* against DoS.

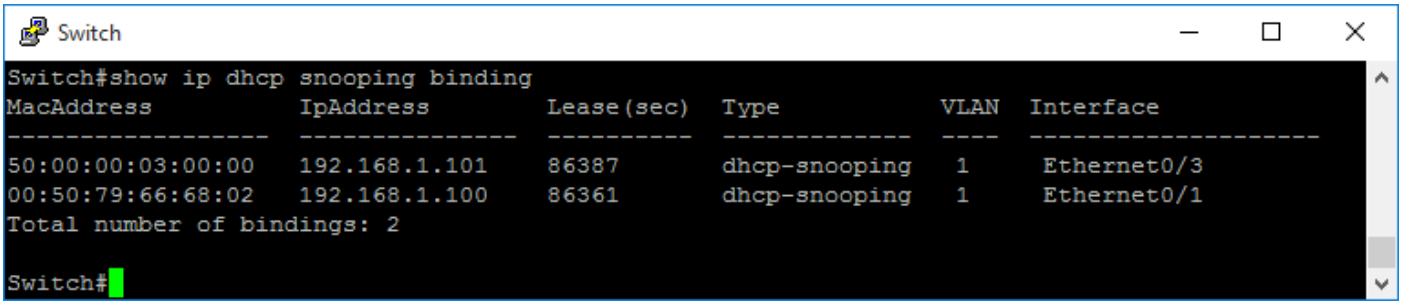


4. Cancel this attack and close Yersinia.

5. Open Ettercap, switch to unified bridging (Ctrl+U) and setup spoof DHCP server functionality (“Mitm -> DHCP Spoofing”)

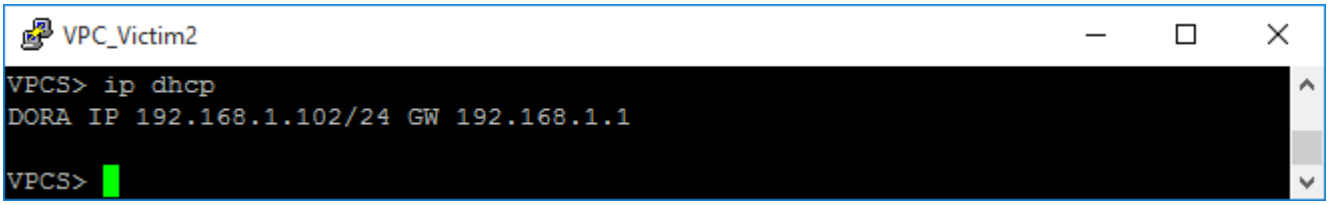


6. DHCP Snooping on *Switch* tracks DHCP messages and binding of addresses. Also DHCP Snooping discards traffic from illegitimate DHCP server on *Linux_Attacker*, thus protecting others from its influence

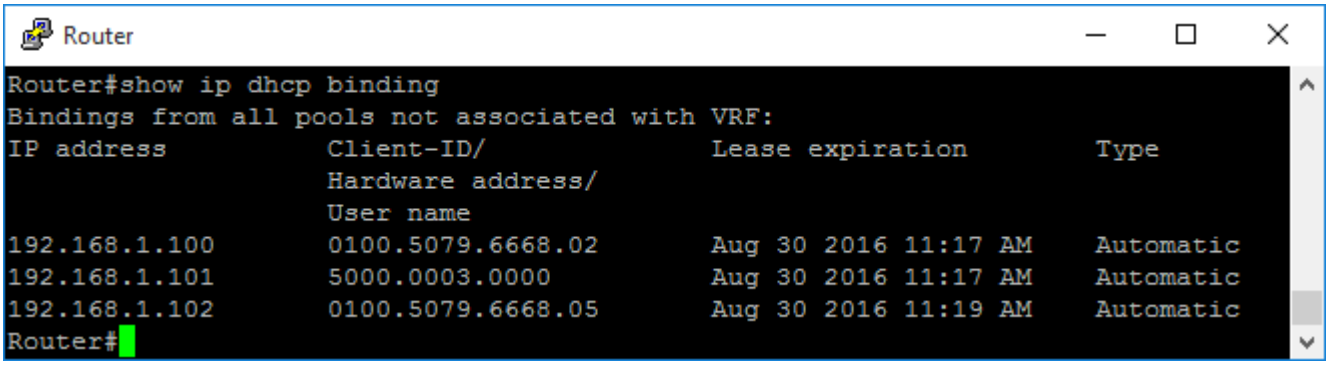


7. Apply for address lease on *VPC_Victim2*

```
VPCS> ip dhcp
```



8. Check DHCP bindings on *Router*



9. Check DHCP Snooping bindings on *Switch*

